for an attacker to carry out brute-force and dictionary attacks. It should use a random salt for each password to prevent an attacker pre-computing tables of common password hashes.

4. e - HTTP Basic credentials are only Base64-encoded, which as you'll recall from section 3.3.1, is easy to decode to reveal the password.
5. c - TLS provides no availability protections on its own.
6. d - The principle of separation of duties.
7. a - 403 Forbidden. As you'll recall from the start of section 3.6, despite the name, 401 Unauthorized means only that the user is not authenticated.

[1] The RateLimiter API is marked as unstable in Guava, so may change in future versions.

[2] Some services return a 503 Service Unavailable status instead. Either is acceptable, but 429 is more accurate especially if you perform per-client rate-limiting.

[3] The HTTP specifications unfortunately confuse the terms "authentication" and "authorization". As we will see in later chapters, there are authorization schemes that do not involve authentication.

[4] The username is not allowed to contain a colon.

[5] https://tools.ietf.org/html/rfc5802

[6] https://blog.cryptographyengineering.com/2018/10/19/lets-talk-about-pake/

[7] On some systems mkcert certificates are already trusted by curl, so you may be able to skip this step.